



Conception et mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé

Codjo Fréjus Loïc SANGRONIO

Licence Informatique — Option Sécurité Informatique

24 juin 2026

Encadreur :
Ing. Guy KPEDJO

RansomShield

2026-07-04



[OUVERTURE — 0 :00]

Monsieur le Président du jury, Mesdames et Messieurs les membres du jury, bonjour. Je vous remercie pour l'occasion qui m'est donnée de présenter mon travail portant sur la conception et la mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé : RansomShield. Cette présentation durera dix minutes, suivie d'une démonstration live de cinq minutes sur des machines virtuelles réelles.

- 1 Introduction Générale
- 2 Revue de littérature
- 3 Analyse et Conception
- 4 Réalisation et Résultats
- 5 Conclusion et Perspectives

[SOMMAIRE — 0 :30]

Ma présentation s'articule en cinq parties : le contexte et la problématique, la revue de littérature, la conception, la réalisation et les résultats, puis la conclusion. Je terminerai par une courte démonstration live.

Introduction Générale

2026-07-04

RansomShield
└─ Introduction Générale

Introduction Générale

Contexte

L'évolution rapide du numérique expose les organisations aux ransomwares : des logiciels malveillants qui rendent les données inaccessibles puis exigent une rançon.

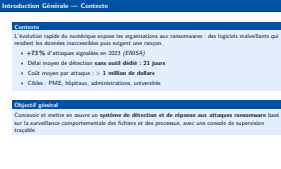
- +73 % d'attaques signalées en 2023 (ENISA)
- Délai moyen de détection **sans outil dédié : 21 jours**
- Coût moyen par attaque : > **1 million de dollars**
- Cibles : PME, hôpitaux, administrations, universités

Objectif général

Concevoir et mettre en œuvre un **système de détection et de réponse aux attaques ransomware** basé sur la surveillance comportementale des fichiers et des processus, avec une console de supervision traçable.

[CONTEXTE — 1 :00]

Les organisations dépendent aujourd'hui fortement de leurs systèmes informatiques, ce qui les expose de plus en plus aux cyberattaques — en particulier au ransomware. Selon l'ENISA, ces attaques ont augmenté de 73 % en 2023 ; sans outil dédié, il faut en moyenne 21 jours pour les détecter.



La détection comportementale en temps réel des attaques ransomware, combinée à une réponse maîtrisée avec validation humaine systématique, constitue une solution efficace et démontrable pour protéger un parc de machines hétérogène sans déployer de vrai malware.

Défi #1

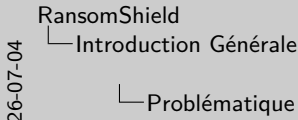
Variantes inconnues contournent les antivirus par signatures

Défi #2

Parc hétérogène (Windows, Linux, macOS) à surveiller

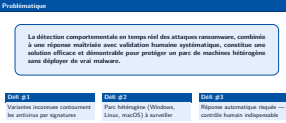
Défi #3

Réponse automatique risquée — contrôle humain indispensable



[PROBLÉMATIQUE — 2 :00]

La problématique est formulée de manière affirmative : la détection comportementale couplée à un contrôle humain constitue la réponse adaptée. Trois défis structurent ce travail : les variantes inconnues, le parc hétérogène, et la nécessité d'un contrôle humain avant chaque action.



Objectifs spécifiques

- Surveiller les événements fichiers en temps réel sur les terminaux
- Analyser les comportements et calculer un score de risque configurable
- Générer automatiquement des alertes et des incidents de sécurité
- Proposer et exécuter des actions de protection avec **contrôle humain**
- Sécuriser la console par une authentification forte (2FA TOTP RFC 6238)
- Valider le pipeline à l'aide de scénarios d'attaque représentatifs

Mémoire rédigé en $\text{\LaTeX}$ selon le canevas IFRI — Licence Informatique, option Sécurité Informatique — Année 2023–2024

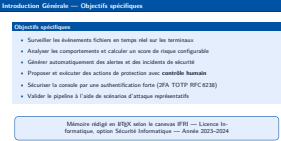
2026-07-04

RansomShield
└─ Introduction Générale

└─ Introduction Générale — Objectifs spécifiques

[OBJECTIFS — 3 :00]

Six objectifs spécifiques guident ce travail : surveillance temps réel, scoring configurable, alertes automatiques, contrôle humain, 2FA et validation par scénarios.



Revue de littérature

2026-07-04

RansomShield
— Revue de littérature

Revue de littérature

Définition d'un ransomware

Un ransomware est un logiciel malveillant qui vise à bloquer l'accès à un système ou à des données, souvent par chiffrement, puis à réclamer une rançon à la victime. (NIST SP 1800-25, CISA)

Comportements caractéristiques — détectables avant les dommages irréversibles

- Renommage massif de fichiers avec extension suspecte (.locked, .enc, .crypt...)
- Création d'une note de rançon (HOW_TO_DECRYPT.txt)
- Suppression des clichés instantanés VSS (vssadmin delete shadows /all)
- Utilisation d'outils légitimes détournés — LOLBins (bcdedit, wmic, vssadmin)
- Suppression massive de fichiers, accès réseau inhabituel

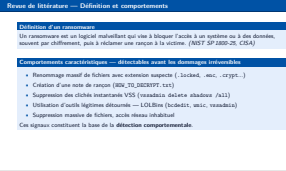
Ces signaux constituent la base de la **détection comportementale**.

RansomShield
└─ Revue de littérature

└─ Revue de littérature — Définition et comportements

[DÉFINITION — 3 :50]

Un ransomware laisse des traces comportementales avant que les dégâts soient irréversibles : extensions suspectes, note de rançon, suppression VSS, LOLBins. Ce sont ces signaux qui forment la base de notre détection.



Solutions existantes

- **Antivirus** — détection par signatures statiques (ClamAV, Windows Defender)
- **SIEM génériques** — collecte de journaux sans corrélation comportementale
- **EDR commerciaux** — CrowdStrike Falcon, SentinelOne, Microsoft Defender XDR

Limites des solutions existantes

- ❌ Contournables par variantes nouvelles, obfuscation ou LOLBins
- ❌ Coût élevé des EDR commerciaux (hors portée académique)
- ❌ Absence d’outil open-source académique démontrable en conditions réelles

Notre réponse : RansomShield

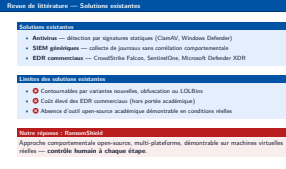
Approche comportementale open-source, multi-plateforme, démontrable sur machines virtuelles réelles — **contrôle humain à chaque étape**.

RansomShield
└─ Revue de littérature

└─ Revue de littérature — Solutions existantes

[SOLUTIONS — 5 :15]

Les antivirus passent à côté des nouvelles variantes. Les EDR commerciaux sont efficaces mais hors de portée académique. RansomShield se positionne dans cet espace.

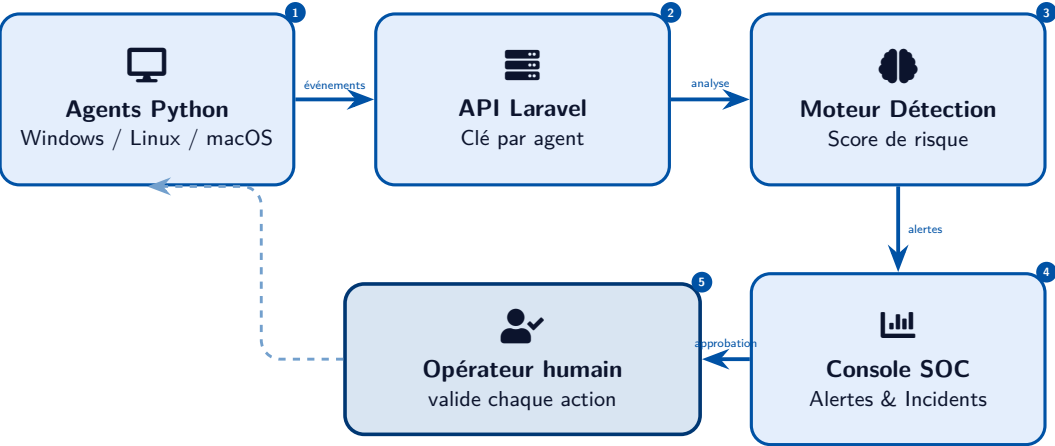


2026-07-04

RansomShield
└ Analyse et Conception

Analyse et Conception

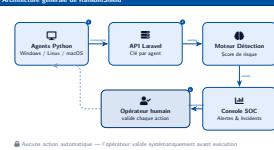
Analyse et Conception



🔒 Aucune action automatique — l'opérateur valide systématiquement avant exécution

2026-07-04

RansomShield
└ Analyse et Conception
└ Architecture générale de RansomShield



[ARCHITECTURE — 6 :15]
L'architecture suit un circuit : les agents envoient les événements à l'API Laravel, le moteur calcule le score, la console SOC affiche les alertes, l'opérateur valide l'action, et la réponse est appliquée sur les agents. Aucune action automatique.

 Agent Python

Surveille les dossiers via **Watchdog** / **inotify**. File locale SQLite (résilience réseau). Enrôlement par token à usage unique. Service systemd — démarrage automatique.

 Découverte réseau

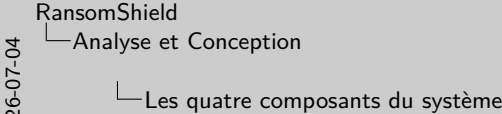
fping (ICMP) + ARP sweep sur les /24. Scan automatique toutes les 5 minutes. Aucun enrôlement sans **validation manuelle admin**.

 Console SOC Laravel

Dashboard temps réel (Chart.js, AJAX 30s). Alertes, incidents, timeline, file d'approbation. Notifications : web, e-mail, son, webhook.

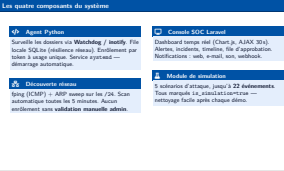
 Module de simulation

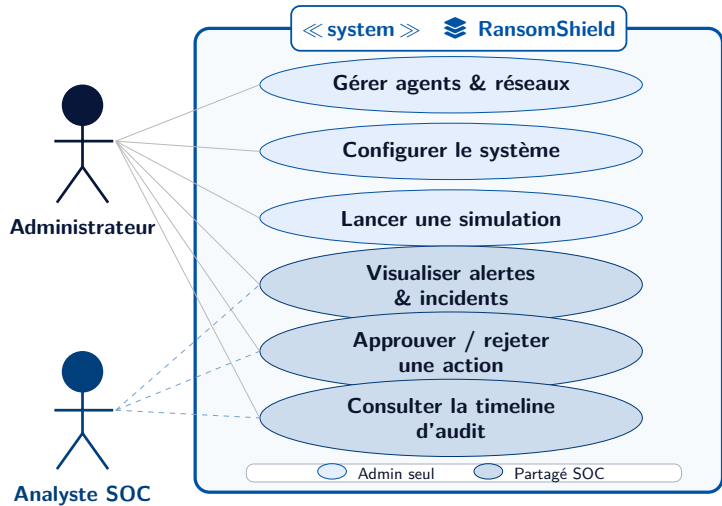
5 scénarios d'attaque, jusqu'à **22 événements**. Tous marqués is_simulation=true — nettoyage facile après chaque démo.



[4 COMPOSANTS — 7 :15]

L'agent surveille en temps réel et conserve une file locale. La console centralise le suivi. La découverte réseau scanne mais exige une validation manuelle. Le module de simulation rejoue des attaques réalistes sans vrai malware.

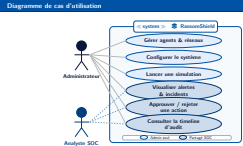




2026-07-04

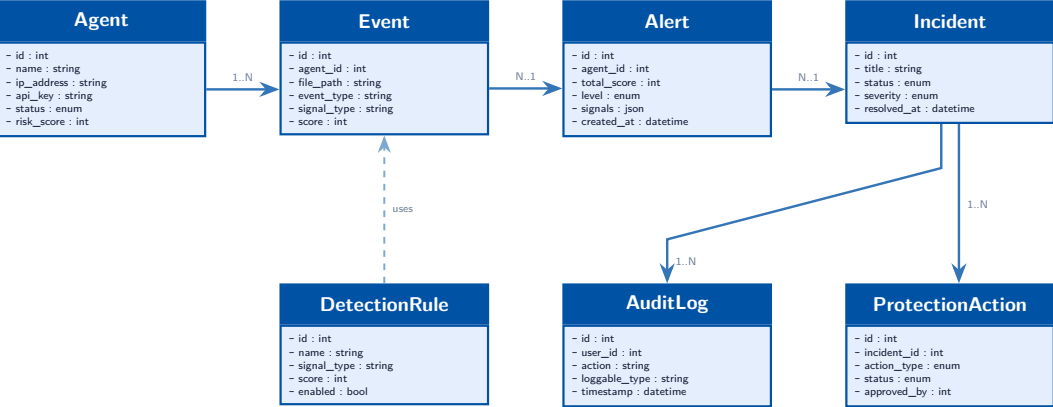
RansomShield

- Analyse et Conception
- Diagramme de cas d'utilisation



[USE CASE — 8 :30]

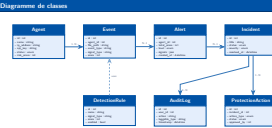
L'administrateur gère les agents, configure le système et lance les simulations. L'analyste SOC se concentre sur le traitement opérationnel : alertes, approbation d'actions, et timeline. Il n'a pas accès à la configuration.



2026-07-04

RansomShield
└ Analyse et Conception

└ Diagramme de classes



[DIAGRAMME DE CLASSES — 9 :15]

Le diagramme montre sept entités. Le pipeline se lit de gauche à droite : Agent génère des Events, évalués par DetectionRule, qui créent des Alerts, escaladées en Incidents. Chaque Incident génère des ProtectionActions et des entrées dans l'AuditLog.

Tables principales

agents	enrôlement, état, risque
events	événements fichiers
alerts	score, niveau, signaux
incidents	fiche, statut, timeline
detection_rules	règles configurables
protection_actions	décisions SOC
audit_logs	traçabilité horodatée
simulation_runs	profils d'attaque

Relations clés

- agents → events (1-N)
- events → alerts (N-1)
- alerts → incidents (N-1)
- incidents → protection_actions (1-N)
- incidents → audit_logs (1-N)
- simulation_runs → events (1-N)

8 tables MySQL — pipeline complet :
événement → alerte → incident → action → audit

2026-07-04

RansomShield
Analyse et Conception
Modèle de données

[MODÈLE DE DONNÉES — 10 :15]

Le modèle repose sur huit tables MySQL. Chaque action est horodatée avec l'identité de l'opérateur qui l'a validée.



Réalisation et Résultats

Backend & Base de données

Laravel 11 / PHP 8.3

MySQL 8.0 (Eloquent ORM)

API REST sécurisée (clé per-agent)

Frontend

Blade (templates Laravel)

Chart.js (intégré local)

AJAX toutes les 30 s

Agent de surveillance

Python 3.10

Watchdog (inotify Linux)

SQLite (file locale offline)

psutil (processus)

Infrastructure de test

3 VMs KVM/libvirt

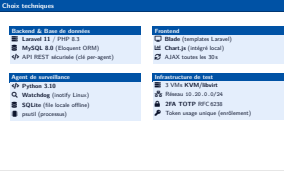
Réseau 10.20.0.0/24

2FA TOTP RFC 6238

Token usage unique (enrôlement)

[CHOIX TECHNIQUES — 11 :30]

Backend Laravel 11, agent Python avec Watchdog, frontend Chart.js en local, tests sur 3 VMs KVM avec 2FA TOTP.



Cycle de vie de l'agent

- 1 Démarrage : lecture .env
- 2 Enrôlement : token → clé API
- 3 Watchdog observe les dossiers
- 4 Événement → file SQLite locale
- 5 POST /api/agent/events
- 6 Heartbeat toutes les 30 s

Installation en une commande :

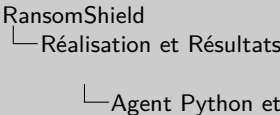
```
curl -sSL http://<soc>/install.sh | bash
```

Scoring comportemental

Signal détecté	Score
Extension suspecte (.locked)	+80
Note de rançon créée	+55
Suppression clichés VSS	+60
LOLBin suspect	+45
Suppression massive fichiers	+50

Score < 30	Normal	
30 à 59	Suspect	
60 à 99	Élevé	Alerte + incident créés automatiquement en < 5 s
≥ 100	Critique	

2026-07-04



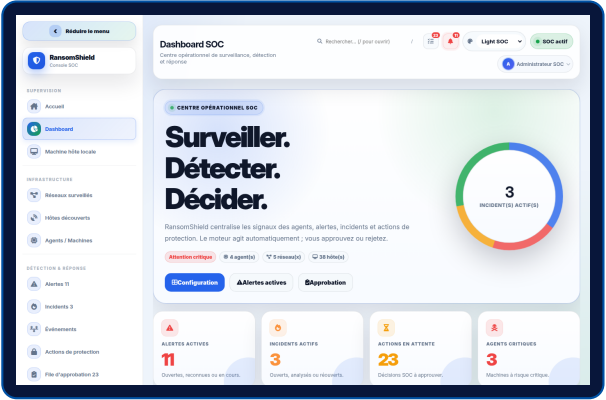
[AGENT — 12 :45]

Un fichier renommé en .locked (+80) et une note de rançon (+55) donnent 135 points : alerte critique et incident créés en moins de cinq secondes.



Pages de la console

- Tableau de bord
- Agents (état, heartbeat)
- Alertes (score, signaux)
- Incidents
- Timeline d’audit
- File d’approbation
- Règles (CRUD live)
- Recherche globale
- Paramètres système



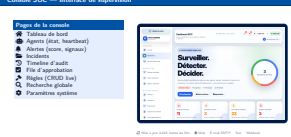
Mise à jour AJAX toutes les 30 s Web · E-mail SMTP · Son · Webhook

- RansomShield
 - Réalisation et Résultats
 - Console SOC — Interface de supervision

2026-07-04

[CONSOLE SOC — 14 :00]

La console centralise neuf pages. Toute action passe par la file d’approbation : l’analyste valide ou rejette explicitement. Les notifications partent sur quatre canaux simultanément.



5 scénarios d'attaque testés

Scénario	Évts	Résultat
Chiffrement basique	7	✓
Kill chain complète	22	✓
Chiffrement massif	18	✓
Exfiltration données	8	✓
LOLBins suspects	5	✓

réseau 10.20.0.0/24

3 VMs KVM —

Résultats obtenus

- ✓ Détection en < 5 secondes (tous scénarios)
- ✓ Aucun événement perdu (file SQLite)
- ✓ Pipeline complet validé bout en bout
- ✓ Rollback isolation réseau fonctionnel
- ✓ 2FA TOTP et API sécurisée (per-agent)

Limite identifiée

Tests conduits sur Linux uniquement. Un attaquant ralentissant son rythme réduit la visibilité.

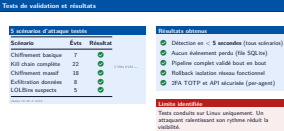
2026-07-04

RansomShield
Réalisation et Résultats

Tests de validation et résultats

[TESTS — 15 :15]

Cinq scénarios validés, de 5 à 22 événements, tous détectés en moins de cinq secondes. Je précise une limite : tests Linux uniquement.





Démonstration Live

5 minutes — système réel sur VMs KVM

2026-07-04

RansomShield
— Réalisation et Résultats

▶ Démonstration Live

5 minutes — système réel sur VMs KVM

[DÉMO LIVE — 16 :00, checklist 5 min, hors chrono présentation]

1. Ouvrir `http://10.20.0.1` (console SOC)
2. Se connecter : identifiants + **code 2FA**
3. Vérifier : 3 agents en ligne (heartbeat vert)
4. **Agents** → VM-02 → **Lancer simulation** → "Kill chain complète"
5. **Dashboard** : le score monte en temps réel
6. **Alertes** : niveau Critique
7. **Incidents** : ouvrir l'incident auto-crée
8. **File d'approbation** : approuver l'isolation réseau
9. **Timeline** : tout est horodaté et tracé

Rester calme, ne pas se précipiter.

Conclusion et Perspectives

2026-07-04

RansomShield
Conclusion et Perspectives

Conclusion et Perspectives

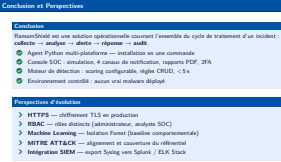
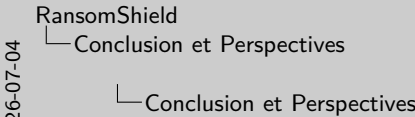
Conclusion

RansomShield est une solution opérationnelle couvrant l'ensemble du cycle de traitement d'un incident : **collecte** → **analyse** → **alerte** → **réponse** → **audit**.

- ✓ Agent Python multi-plateforme — installation en une commande
- ✓ Console SOC : simulation, 4 canaux de notification, rapports PDF, 2FA
- ✓ Moteur de détection : scoring configurable, règles CRUD, < 5 s
- ✓ Environnement contrôlé : aucun vrai malware déployé

Perspectives d'évolution

- **HTTPS** — chiffrement TLS en production
- **RBAC** — rôles distincts (administrateur, analyste SOC)
- **Machine Learning** — Isolation Forest (baseline comportementale)
- **MITRE ATT&CK** — alignement et couverture du référentiel
- **Intégration SIEM** — export Syslog vers Splunk / ELK Stack



[CONCLUSION — 20 :00]

RansomShield couvre tout le cycle d'un incident. Ses limites sont assumées : tests Linux, LAN sans HTTPS. Les perspectives visent HTTPS, RBAC, ML et MITRE ATT&CK.

Merci de votre attention !

Codjo Fréjus Loïc SANGRONIO

lsangronio@gmail.com | IFRI-UAC · 2023–2024

Encadreur : Ing. Guy KPEDJO

2026-07-04

RansomShield
Conclusion et Perspectives

Merci de votre attention !

Codjo Fréjus Loïc SANGRONIO
lsangronio@gmail.com | IFRI-UAC · 2023–2024
Encadreur : Ing. Guy KPEDJO

[QUESTIONS DU JURY]

- **Pourquoi Python et pas C/Go ?** Watchdog exploite inotify nativement, CPU minimal, portable
- **Faux positifs ?** Seuils configurables, opérateur humain valide ou rejette
- **Pourquoi pas HTTPS ?** LAN contrôlé ; 1^{re} perspective pour la prod
- **Différence avec un antivirus ?** Comportement, pas signature ; variantes inconnues couvertes
- **Testé sur Windows ?** Non, limite assumée : Linux uniquement

Garder les *annexes* prêtes.